

SECUREPAY SOLUTIONS PVT. LTD.

ACCESS CONTROL POLICY

Policy ID: SP-GRC-POL-001 | Version: 1.0 | Status: Draft / Portfolio Sample

Policy Owner	Information Security / GRC
Effective Date	September 2026
Review Frequency	At least annually and after significant changes
Classification	Internal – Simulated

Portfolio disclaimer: SecurePay Solutions Pvt. Ltd. is fictional. This document is a simulated policy created for educational and portfolio purposes and is not an approved policy of a real organization.

1. Purpose

The purpose of this policy is to ensure that access to SecurePay information, applications, infrastructure, and data is authorized, appropriate, reviewed, and removed when no longer required.

2. Scope

This policy applies to employees, contractors, administrators, service accounts, applications, databases, cloud resources, network systems, and other information assets managed by SecurePay.

3. Access Management Principles

- Least privilege: users receive only the access required for their job duties.
- Need-to-know: access to sensitive information is limited to authorized business purposes.
- Role-based access: permissions should be assigned according to approved roles and responsibilities.
- Segregation of duties: conflicting responsibilities should be separated where practical.
- Access must be approved before it is provisioned.

4. User Access Provisioning

- Managers request access for new users and identify required roles.
- The appropriate system or data owner approves access before provisioning.
- IT/IAM personnel create accounts using approved roles and permissions.
- Access should be documented in the organization's access records.
- Generic or shared accounts should be avoided unless formally approved and controlled.

5. Privileged Access

- Administrative access must be limited to authorized personnel.
- Privileged users should use separate administrative accounts where technically feasible.
- Privileged activity should be logged and monitored.
- Administrative permissions should be reviewed periodically.

6. Access Reviews

- User access should be reviewed at least quarterly for critical systems.
- Managers and system owners are responsible for confirming continued business need.

- Unnecessary, excessive, or inappropriate permissions must be removed promptly.
- Review results and exceptions should be retained as evidence.

7. Employee Offboarding

- HR or the relevant manager must notify IT/IAM when an employee leaves or changes role.
- User accounts should be disabled promptly based on the organization's offboarding procedure.
- VPN, application, cloud, email, and privileged access should be revoked as applicable.
- Company assets and credentials must be returned or deactivated.

8. MFA Requirements

Multi-factor authentication should be enabled for privileged accounts, remote access, externally accessible services, and other systems identified as high risk.

9. Responsibilities

- IT/IAM: provision, modify, review, and revoke access; maintain access records.
- Managers: approve access based on job responsibilities and confirm periodic reviews.
- System/Data Owners: define appropriate permissions and approve sensitive access.
- Employees: protect credentials and use access only for authorized business purposes.

10. Policy Violations

Unauthorized access, credential sharing, attempts to bypass access controls, or misuse of privileges may result in investigation and disciplinary action in accordance with applicable organizational procedures.

11. Exceptions

Exceptions must be documented, justified by a business need, approved by the appropriate owner, and reviewed for compensating controls and expiration.

12. Review

The policy should be reviewed at least annually and whenever significant changes occur to business processes, technology, threats, or applicable requirements.